

CURSO

PROCESSO DE GESTÃO DE RISCOS DE PRIVACIDADE

Módulo II

Diretrizes e práticas para identificar, avaliar, tratar, monitorar e comunicar riscos de privacidade na ANAC.



PROTEGER
INFORMAÇÕES



PRESERVAR A
PRIVACIDADE



GARANTIR
CONFORMIDADE



FORTALECER A
GOVERNANÇA

Conteúdo

Módulo II:

1. IDENTIFICAÇÃO DE RISCOS
 - a. Identificar ativos
 - b. Identificar ameaças, controles e vulnerabilidades
2. ANÁLISE DE RISCOS
 - a. Avaliar impactos de privacidade
 - b. Avaliar probabilidades
 - c. Estimar nível de riscos
3. AVALIAÇÃO DE RISCOS
 - a. Classificar os riscos
4. ESTUDO DE CASO – PARTE II
5. REFERÊNCIAS BIBLIOGRÁFICAS



Ao final deste Módulo, esperamos que você seja capaz de:

- I – Identificar e descrever os riscos no escopo do processo de Gestão de Riscos de Privacidade, assim como as consequências adversas resultantes;
- II – Analisar os riscos identificados, calculando os possíveis impactos de privacidade;
- III – Estimar as probabilidades e classificar o nível dos riscos identificados, registrando-os em uma Mapa de Riscos.

1. IDENTIFICAÇÃO DE RISCOS

Essa etapa trata da identificação e descrição de riscos no escopo do processo de **Gestão de Riscos de Privacidade** e das consequências adversas resultantes. Busca-se compreender as possíveis ameaças e vulnerabilidades existentes e avaliar a extensão e a adequação dos controles utilizados.

Para fins de priorização, pode-se utilizar os riscos identificados no Processo de Gestão de Riscos Corporativo para focar os esforços e recursos primeiro em setores mais críticos e, depois, nos sucessivamente menos críticos.

Importante destacar que existem ameaças e vulnerabilidades que impactam a organização como um todo e, dessa forma, deve-se priorizar o tratamento dessas ameaças também.



Essa fase é composta pelas seguintes atividades:

- I. Identificar ativos; e
- II. Identificar ameaças, controles e vulnerabilidades.

Identificar ativos

Nesta atividade são identificados os ativos que estão no escopo do Processo de GRPSI, incluindo ativos de informação e ativos relacionados ao tratamento de dados pessoais.

A imagem abaixo apresenta os tipos de ativos para a identificação e registro que, de modo geral, se dividem em Ativos primários e Ativos de suporte:



Dentro deste curso abordaremos principalmente o tratamento de dados pessoais.

As listas dispostas na imagem acima são apenas exemplificativas, neste sentido, deveremos sempre avaliar quais subconjuntos desses tipos de ativos serão abordados no processo.

Cada Responsável Pela Unidade Organizacional, juntamente com o gestor de riscos, devem retomar as informações geradas nas atividades da etapa “Estabelecer Contexto” para definir como abordar a gestão de riscos em sua unidade, definindo o nível de detalhamento a ser adotado na identificação de cada ativo.

Os gestores de risco, com apoio dos responsáveis pelos ativos, devem identificar e registrar no Mapa de Riscos cada ativo que faz parte do escopo do Processo de Gestão de Riscos de Privacidade, principalmente aqueles que envolvam tratamento de dados pessoais, conforme demonstrado na imagem abaixo:



Esta tarefa é realizada em cada unidade da organização no escopo do Processo de GRPSI, em ordem priorizada por criticidade. O resultado da tarefa é o cadastro de cada ativo em cada unidade da organização que faz parte do escopo do Processo de GRPSI.

O gestor de riscos deve avaliar as informações sobre ativos no Mapa de Riscos.

Identificar ameaças, controles e vulnerabilidades

Para cada ativo identificado, devem ser analisadas e identificadas as ameaças, os controles e as vulnerabilidades associadas relacionadas ao tratamento de dados pessoais e à proteção da privacidade, quando aplicável.

O responsável pelos ativos deve, com o acompanhamento do responsável pela unidade organizacional, identificar para cada ativo, no Mapa de Riscos, as ameaças existentes (vide Anexo I – Lista de Ameaças), relacionadas à violação de dados pessoais, acesso não

autorizado, uso indevido ou tratamento inadequado de dados pessoais, bem como descrever essas ameaças.

Devem ser informados também os controles aplicáveis e a situação de implementação de cada controle (implementado ou não implementado). Para auxiliar na identificação de possíveis controles, devem ser utilizados catálogos de controles associados às ameaças, como os existentes nas normas ABNT NBR ISO/IEC 27002:2022 e ABNT NBR ISO/IEC 27701:2026

A partir da análise dos controles, devem ser identificadas, no Mapa de Riscos, as vulnerabilidades (vide Anexo II – Lista de Vulnerabilidades) para as quais não há controles implementados e cuja exploração por uma ameaça pode incorrer em uma violação de segurança com incidente envolvendo dados pessoais.



O Responsável pela Unidade Organizacional deve avaliar, no Mapa de Riscos, as informações das ameaças, controles e vulnerabilidades relacionadas aos ativos da unidade.

Caso não estejam de acordo, o Responsável Pela Unidade Organizacional deve realizar, juntamente com o Responsável Pelos Ativos, as alterações necessárias no Mapa de Riscos.

O gestor de riscos deve avaliar as informações no Mapa de Riscos e caso não esteja de acordo, deve notificar o Responsável Pela Unidade Organizacional da necessidade de reexecutar uma ou mais das tarefas anteriores e informar o

prazo para conclusão das tarefas, bem como as orientações para aprimoramento das informações.

2. ANÁLISE DE RISCOS

Esta etapa trata da estimação dos riscos identificados, incluindo aqueles relacionados à proteção de dados pessoais.

A estimativa visa compreender o impacto das consequências provocadas caso as ameaças aos ativos ocorram de fato, definindo quantitativamente o nível de impacto.

Também é necessário estimar as probabilidades das ameaças se efetivarem.



Avaliar impactos de privacidade

A avaliação do impacto no escopo de privacidade se concentra na análise da gravidade dos potenciais efeitos sobre os direitos e as liberdades fundamentais dos titulares de dados pessoais, em conformidade com os princípios estabelecidos pela LGPD.

O processo de gestão de riscos de privacidade também contribui para demonstrar a adoção de medidas de governança e conformidade com a LGPD, em observância ao princípio da responsabilização e prestação de contas.

Nesse contexto, o impacto sobre a privacidade deve considerar as seguintes fontes de informação:

- Informações históricas sobre incidentes envolvendo dados pessoais;
- Controles existentes, considerando que a existência de controles eficazes pode reduzir o impacto potencial, enquanto sua ausência pode ampliá-lo;
- O grau de exposição ou acessibilidade das informações;
- A natureza dos dados pessoais tratados, com especial atenção aos dados pessoais sensíveis;
- O volume de titulares potencialmente afetados;
- O tratamento de dados de crianças e adolescentes;
- A extensão, a severidade e a reversibilidade dos prejuízos potenciais.



Conforme demonstrado na imagem acima, a avaliação do impacto em privacidade considera 4 (quatro) atributos: volume de titulares afetados, sensibilidade dos dados, impacto nos direitos e liberdades do titular e duração do impacto.

O resultado para cada atributo é consolidado por meio da função: $I = Fp(VT, SD, DL, TI)$, onde:

- I: Impacto.
- Fp: Função de consolidação de impacto de privacidade.
- VT: Impacto relativo ao volume de titulares afetados.
- SD: Impacto relativo à sensibilidade dos dados.
- DL: Impacto relativo aos direitos e liberdades dos titulares.
- TI: Impacto relativo à duração do impacto sobre os direitos e liberdades dos titulares.

O valor do impacto resulta no maior valor entre VT, SD, DL, TI.

O resultado desta atividade é a estimativa de impacto para cada risco e a classificação desse impacto em uma determinado classe, conforma a ilustração abaixo demonstra:



A avaliação de impacto de privacidade busca estimar o grau de risco aos direitos e às liberdades fundamentais dos titulares de dados pessoais, subsidiando a adoção de medidas de mitigação e tratamento de riscos, em conformidade com a LGPD.

Quando identificado risco elevado aos direitos e liberdades dos titulares, poderá ser necessária a elaboração de Relatório de Impacto à Proteção de Dados Pessoais - RIPD, nos termos da LGPD e das orientações da Autoridade Nacional de Proteção de Dados - ANPD.

Avaliar probabilidades

Os responsáveis pelos ativos definem, no Mapa de Riscos, as probabilidades dos riscos, ou seja, a probabilidade de que as ameaças se concretizem e provoquem incidentes ou danos aos ativos relacionados ao tratamento de dados pessoais.

Esta avaliação pode ser baseada nos seguintes elementos:

- ✓ Informações estatísticas gerais sobre a probabilidade de incidentes;
- ✓ Informações da organização sobre histórico de ocorrência de incidentes;
- ✓ Informações da organização sobre a frequência ou a periodicidade de ocorrência de uma ameaça específica;
- ✓ Para ações causadas propositalmente:
 - As fontes de ameaça;
 - Características de capacidade da fonte em causar danos;
 - Características de intenção e motivação de fonte em causar danos;
 - Percepção exterior da atratividade e vulnerabilidade do ativo;
 - Facilidade para converter a exploração da vulnerabilidade do ativo em uma recompensa;
- ✓ Para ações causadas acidentalmente:
 - Fatores geográficos propensos a gerar problemas;
 - Fatores que podem favorecer erros humanos ou falhas de equipamentos;
- ✓ Avaliação sobre eficiência dos controles existentes.

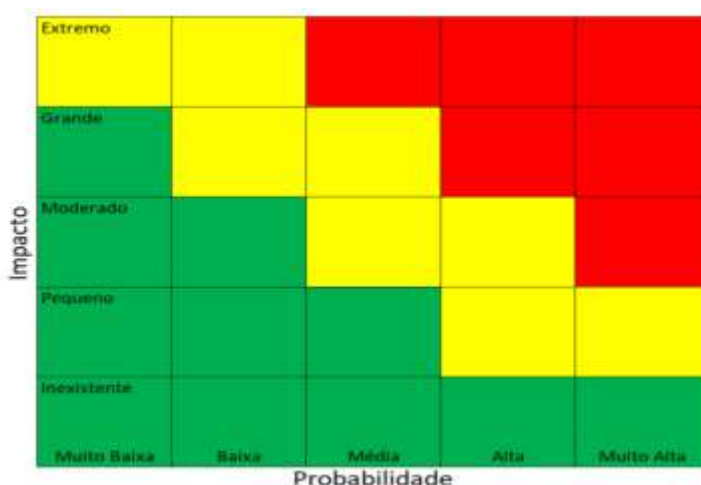
Assim como ilustrado na imagem abaixo, para cada risco mapeado deve ser identificada a classe de probabilidade do risco se materializar e justificar a classificação.



Estimar nível de risco

Os Responsáveis pelos ativos, com o apoio dos Responsáveis pelas Unidades, devem consolidar as estimativas de impacto e de probabilidade visando calcular o nível de risco para cada ameaça ou evento que possa afetar o tratamento de dados pessoais.

O nível de risco e a classe são calculados pela relação impacto x probabilidade, resultando na figura abaixo que demonstra o apetite ao risco em termos de impacto e probabilidade:



A Tabela a seguir, apresenta as diretrizes de tratamento para cada evento de risco em razão da estimativa do nível de risco:

Nível de Risco	Ações de tratamento, comunicação e monitoramento
Alto	1. Indica um risco além do apetite a risco da instituição. 2. Qualquer risco encontrado nessa área deve ter uma resposta, seja para eliminar o risco, ou diminuir seu impacto ou probabilidade. 3. O CSIP deverá ter conhecimento de todos os riscos enquadrados nesse nível. 4. Admite-se postergar o tratamento somente com autorização do Comitê.
Médio	1. Indica um risco além do apetite a risco da instituição. 2. Qualquer risco encontrado nessa área deve ter uma resposta, seja para eliminar o risco, ou diminuir seu impacto ou probabilidade. 3. O CSIP deverá ter conhecimento de todos os riscos enquadrados nesse nível - Admite-se postergar o tratamento somente com autorização do titular máximo.
Baixo	1. Indica um nível de risco aceitável para a instituição. 2. Não se faz necessário adotar medidas especiais para tratamento do risco.

O resultado desta atividade é um Mapa de Riscos, com cada risco identificando:

- ✓ Ativo;
- ✓ Ameaça ao ativo;

- ✓ Estimativa de impacto;
- ✓ Justificativa para a estimativa de impacto;
- ✓ Estimativa de probabilidade;
- ✓ Nível de risco (alto, médio ou baixo).

3. AVALIAÇÃO DOS RISCOS

Neste ponto do processo de Gestão de Riscos de Privacidade, há uma visão mais clara de quais ameaças existem para os ativos e para o tratamento de dados pessoais, bem como do nível de proteção desses ativos por meio de controles.



Além disso, neste ponto já foi estimado o nível dos riscos resultantes de impactos e probabilidades apuradas. O objetivo agora é classificar os riscos visando identificar os mais expressivos e estabelecer estratégias de resposta a esses riscos.

Classificar os Riscos

Nesta etapa, o gestor de riscos deve classificar ordenadamente os riscos e ameaças de privacidade no Mapa de Riscos, permitindo distinguir os riscos mais relevantes, subsidiando as decisões sobre quais riscos devem ser tratados prioritariamente.

Posteriormente, o gestor de riscos deve dar ciência aos Responsáveis Pelas Unidades Organizacionais para que informem o prazo para tratamento, o que será detalhado no próximo módulo do curso.

4. ESTUDO DE CASO – PARTE II

Cenário hipotético - Continuação

Assim como vimos no primeiro módulo do curso, A ANAC identificou a necessidade de realizar uma avaliação de riscos específica para o sistema SACI, que gerencia os Certificados Médicos Aeronáuticos (CMA), visto que se trata de dados pessoais sensíveis de milhares de regulados.



Neste sentido, o **Gestor de Riscos**, com apoio dos **Responsáveis por Ativos**, avançou para a etapa de identificação e análise técnica das incertezas que cercam o SACI, principalmente quanto à confiabilidade do módulo de acesso ao sistema.

1. Identificação de Ativos, Ameaças e Vulnerabilidades

Nesta etapa, o ativo crítico foi detalhado e as fraquezas foram mapeadas conforme os anexos normativos:

- **Ativo:** Banco de dados de regulados do sistema SACI (contendo dados pessoais sensíveis).
- **Ameaças (Anexo I):** "Acesso não autorizado a sistemas de TI" e "Vazamento ou divulgação de informações confidenciais".
- **Vulnerabilidades (Anexo II):** "Configurações inseguras" (devido ao uso de autenticação simples) e "Criptografia não habilitada".

2. Identificação de Controles Aplicáveis

Ao consultar o catálogo da ABNT NBR ISO/IEC 27701:2026, a equipe identificou os controles necessários para proteger a privacidade, registrando sua situação atual no Mapa de Riscos:

- **Autenticação segura (A.3.23):** Necessária para substituir a autenticação simples.
Situação: Não implementado.
- **Uso de criptografia (A.3.26):** Necessária para proteger dados pessoais sensíveis.
Situação: Não implementado.
- **Log (A.3.25):** Necessário para rastrear acessos e tentativas de invasão.
Situação: Parcialmente implementado (logs básicos sem alertas automatizados).

3. Avaliação de Impacto de Privacidade baseada nos 4 Atributos

Para estimar o impacto, utilizaremos uma escala de 1 a 5 (onde 1 é "Inexistente" e 5 é "Extremo") para cada atributo, conforme a metodologia apresentada, lembrando que a fórmula de cálculo é $I = Fp(VT, SD, DL, TI)$, onde:

- I: Impacto.
- Fp: Função de consolidação de impacto de privacidade.
- VT: Impacto relativo ao volume de titulares afetados.
- SD: Impacto relativo à sensibilidade dos dados.
- DL: Impacto relativo aos direitos e liberdades dos titulares.
- TI: Impacto relativo à duração do impacto sobre os direitos e liberdades dos titulares.

Com base na metodologia acima, foi encontrado o seguinte cenário:

- **Impacto de Privacidade:** Definido como **5 (Extremo)**. O cálculo considerou o maior valor entre os atributos, com destaque para a **Sensibilidade dos Dados (SD)** de saúde e o alto **Volume de Titulares (VT)** afetados.

A imagem a seguir ilustra e reforça os conceitos envolvidos na classificação adotada:



2. Avaliação de Probabilidades

A avaliação de probabilidades tem escala de 1 a 5, onde 1 é muito baixa e 5 muito alta.

Considerando o histórico estatístico de tentativas de ataque e as falhas técnicas identificadas (vulnerabilidade do ativo), os responsáveis avaliam as chances de o risco se materializar como:

- **Probabilidade:** Estimada em **4 (Alta)**, devido à "Atratividade do Ativo" para ataques externos e à "Eficiência dos controles existentes" ser considerada baixa.

3. Estimativa do Nível de Risco

O nível de risco é a relação entre **Impacto (5) x Probabilidade (4)**. De acordo com as diretrizes do processo, um risco com impacto “Extremo” e probabilidade “Alta”, dentro da escala de medição adotada, recebe o nível de risco **Alto**.



4. Mapa de riscos

O risco foi devidamente registrado no Mapa de Riscos evidenciando que a falta de controles previstos na ISO 27701 coloca os dados sensíveis em perigo.

Este diagnóstico subsidiará a próxima etapa, onde o Gestor de Riscos deverá dar ciência aos responsáveis para que estabeleçam os prazos de tratamento.

O **Anexo V** apresenta o Mapa de Riscos preenchido com os dados referentes ao cenário hipotético estabelecido neste Estudo de Caso.

5. REFERÊNCIAS BIBLIOGRÁFICAS

1. AGÊNCIA NACIONAL DE AVIAÇÃO CIVIL. **Processo de gestão de privacidade segurança da informação**. Brasília: ANAC, 2026. 29 p.
2. ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **Segurança da informação, segurança cibernética e proteção à privacidade: controles de segurança da informação** = Information security, cybersecurity and privacy protection: information security controls. 3. ed. Rio de Janeiro, 2022. (ABNT NBR ISO/IEC 27002:2022)
3. ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **Segurança da informação, segurança cibernética e proteção da privacidade: sistemas de gestão da privacidade da informação: requisitos e orientações** = Information security, cybersecurity and privacy protection : privacy information management systems : requirements and guidance. 2. ed. Rio de Janeiro, 2026. (ABNT NBR ISO/IEC 27701:2026)